

Retrieved from Cache (Systemic)

Assessment Identifier: **WS-DYN-13** | Assessment Type: **Dynamic** | Date: **September 08, 2026**

Severity: INFORMATIONAL	CVSS: 0.0	CWE: CWE-525
OWASP: A05:2021 - Security Misconfiguration	WASC ID: 13	Confidence: Medium
Target / Component: API Story Redirect Service	Affected URL: https://www.worldmonitor.app/api/story	Parameter: Age Header / Shared Cache Proxy

1. Description

The content was retrieved from a shared cache. If the response data is sensitive, personal, or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network (e.g., corporate or educational environments).

2. Steps to Reproduce

1. Send an HTTP GET request to https://www.worldmonitor.app/api/story.
2. Inspect the returned HTTP response headers.
3. Check for the presence of the Age header (e.g., Age: 0), indicating that the response passed through or was served by an HTTP/1.1 compliant caching proxy.

3. Controlled Proof of Concept

```

HTTP/1.1 302 Found
Date: Tue, 08 Sep 2026 10:28:35 GMT
Connection: keep-alive
Age: 0
Cache-Control: private, no-store

Bash Check:
curl -I -s https://www.worldmonitor.app/api/story | grep -i "Age:"
  
```

4. Business & Security Impact

When an application routes through intermediary proxy caches, responses marked with an Age header indicate shared cache participation. If sensitive dynamic API data or authentication redirects are cached on upstream network proxies, other users sharing the same network proxy could receive cached responses containing another user's session state or sensitive payload.

5. Remediation Recommendations

Primary Fix: Validate that API endpoints do not expose sensitive data to upstream caching proxies.

1. Validate that the response does not contain sensitive, personal, or user-specific information.
2. For sensitive or session-bound API endpoints, ensure the application sends non-cacheable directives to prevent intermediate storage:

Cache-Control: no-cache, no-store, must-revalidate, private
Pragma: no-cache
Expires: 0

6. Evidence & Validation

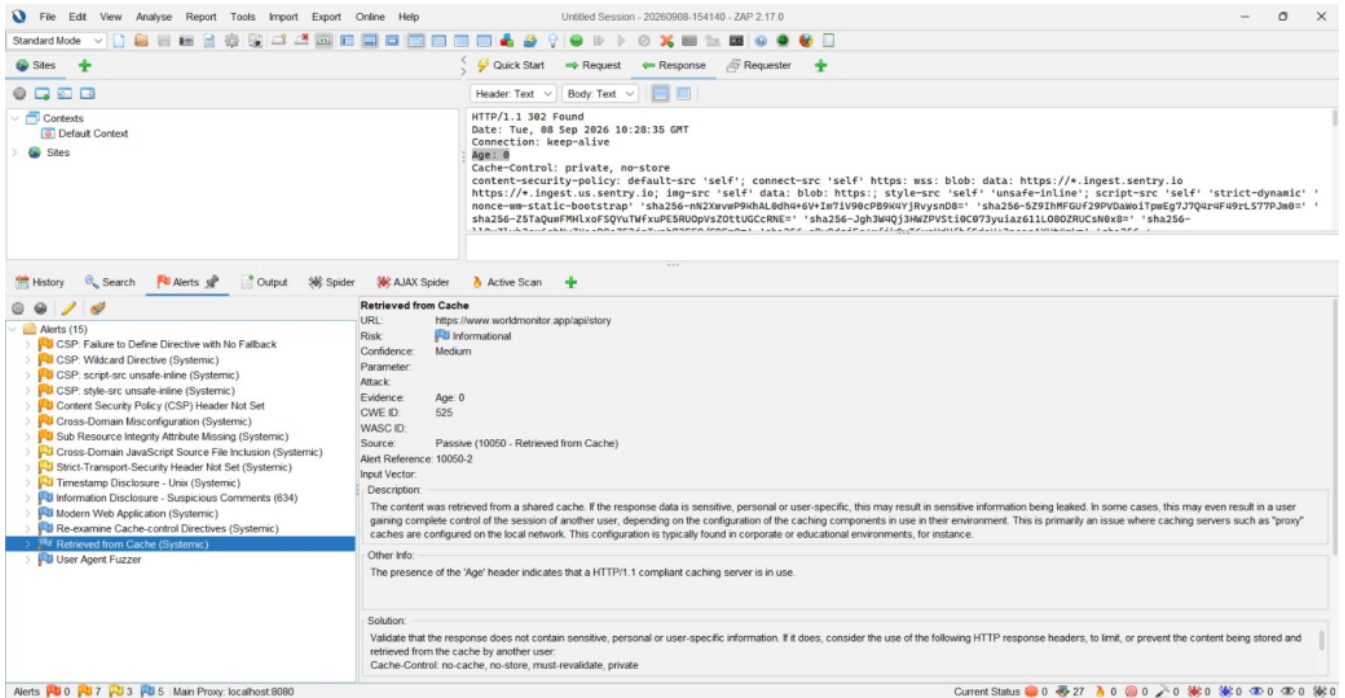


Figure 1: Matched Proof-of-Concept Screenshot for Vulnerability #13 (13/poc-1.png)

Authorization & Safety Compliance: This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.